

Guía Metodológica de la Encuesta GRC de Ciberseguridad en España

1. Objetivo de la encuesta

La encuesta pretende medir el nivel de madurez en gobernanza, gestión de riesgos y cumplimiento (GRC) de la ciberseguridad en organizaciones que operan en España, con capacidad de comparación nacional e internacional. Se inspira en marcos de referencia como NIS2/NIS360 (ENISA), NIST CSF 2.0 y RMF, así como en estrategias nacionales y europeas de ciberseguridad.[web:9][web:12][web:13]

El propósito último es disponer de un Índice Global de Madurez (IGM) y de insumos para estimar el retorno de la inversión (ROI) en ciberseguridad a nivel organizativo y sectorial.[web:1][web:3]

2. Población objetivo y unidad de análisis

- Población objetivo: organizaciones públicas y privadas con operación relevante en España, especialmente operadores esenciales, entidades importantes y sectores regulados.
- Unidad de análisis: cada organización responde una única encuesta, a ser cumplimentada por el CISO, CIO, responsable de riesgos o equivalente, con apoyo de otras áreas cuando sea necesario.

3. Estructura del cuestionario

La encuesta se organiza en ocho bloques:

1. Información general de la organización.
2. Gobernanza de la ciberseguridad.
3. Gestión del riesgo de ciberseguridad.
4. Cumplimiento normativo y regulatorio.
5. Capacidades técnicas y Zero Trust.
6. Resiliencia, continuidad y respuesta a incidentes.
7. Inversión, IGM y ROI.
8. Cultura, formación y terceros, con preguntas abiertas.

Cada bloque contribuye a una dimensión de madurez, siguiendo una filosofía cercana a los modelos utilizados por ENISA (NIS360) y por índices industriales como Cisco Readiness Index.[web:9][web:12][web:1]

4. Escalas de respuesta y codificación

4.1. Escalas ordinales de madurez

La mayoría de las preguntas cerradas utilizan escalas ordinales que representan niveles crecientes de madurez. Por ejemplo:

- 0 – Inexistente.
- 1 – Ad hoc / reactivo.
- 2 – Definido.
- 3 – Implementado.
- 4 – Gestionado y medido.
- 5 – Optimizado / integrado.

La codificación exacta se definirá en la plantilla de Excel de cálculo del IGM. La recomendación es asignar un valor numérico a cada opción de respuesta siguiendo la lógica de mayor madurez, evitando escalas “tramposas” que degraden la honradez del encuestado.

4.2. Respuestas múltiples

En preguntas donde se permite seleccionar varias opciones (p. ej. marcos normativos aplicables), cada opción se codifica como variable binaria (0/1). Posteriormente, podrán derivarse índices compuestos, como “densidad normativa” o “nivel de exigencia regulatoria”.

4.3. Respuestas abiertas

Las respuestas abiertas no se codificarán inicialmente, pero se recomienda aplicar técnicas de análisis cualitativo y, en la medida de lo posible, categorización posterior para extraer patrones.

5. Cálculo del Índice Global de Madurez (IGM)

5.1. Dimensiones propuestas

Se propone que el IGM agregue, al menos, las siguientes dimensiones:

- IG_GOB: Gobernanza (bloque 2).
- IG_RIESGO: Gestión de riesgos (bloque 3).
- IG_CUMP: Cumplimiento normativo (bloque 4).
- IG_ZT: Capacidades técnicas y Zero Trust (bloque 5).
- IG_RES: Resiliencia y continuidad (bloque 5-6).
- IG_CULT: Cultura, formación y terceros (bloque 7).

Cada subíndice se calcula como la media ponderada de las preguntas asociadas, con pesos definidos por relevancia normativa y de riesgo.

5.2. Ponderación sugerida

A modo de ejemplo, se propone:

- IG_GOB: 20 %.
- IG_RIESGO: 20 %.
- IG_CUMP: 20 %.
- IG_ZT: 20 %.
- IG_RES: 10 %.
- IG_CULT: 10 %.

Estas ponderaciones pueden ajustarse según el sector o la prioridad estratégica (por ejemplo, mayor peso de resiliencia en infraestructuras críticas).

5.3. Normalización

Cada subíndice se normaliza a una escala 0–100, donde 0 representa ausencia total de capacidades y 100 un nivel de excelencia equiparable a buenas prácticas internacionales. El IGM global será la suma ponderada de los subíndices normalizados.

6. Enfoque para el ROI en ciberseguridad

El ROI en ciberseguridad no se calculará a partir de una fórmula única, sino de un conjunto de variables:

- % de presupuesto TI dedicado a ciberseguridad.
- Evolución de ese presupuesto en 3 años.
- Nivel de madurez (IGM).
- Frecuencia y severidad de incidentes (si se recogen datos adicionales en extensiones de la encuesta).
- Reducción estimada de pérdida esperada (cuando se disponga de modelos de riesgo cuantitativos).

La plantilla Excel propondrá un modelo básico de ROI basado en la reducción de la pérdida anual esperada (ALE) atribuible a la mejora de madurez, con una generosa dosis de prudencia epistemológica.

7. Calidad de datos y sesgos

7.1. Sesgo de autocomplacencia

Es razonable esperar que algunos encuestados sobreestimen su madurez. Se recomienda:

- Enviar la encuesta con carta de presentación que subraye la importancia de la honestidad.
- Garantizar confidencialidad y anonimato en los resultados agregados.
- Realizar muestras piloto para detectar patrones de respuesta “milagrosamente excelentes”.

7.2. Sesgo de desconocimiento

En organizaciones poco maduras, el encuestado puede no conocer detalles. Se sugiere:

- Permitir la respuesta “No sabe / No aplica” donde tenga sentido.
- Acompañar la encuesta con glosario mínimo de términos.

8. Implementación práctica

8.1. Formato

La encuesta puede implementarse en:

- Formularios web (preferible para agregación automática).
- Herramientas de encuesta estándar (por ejemplo, plataformas de investigación).
- Formularios ofimáticos, para casos extremos o nostálgicos.

8.2. Duración y esfuerzo

Se recomienda no exceder 30–40 minutos de duración total. El número de preguntas está diseñado para equilibrar profundidad y fatiga, con la consciencia de que nadie quiere pasar una tarde entera contestando sobre microsegmentación.

9. Uso de resultados

Los resultados servirán para:

- Elaborar informes sectoriales y nacionales de madurez GRC.
- Identificar brechas en relación con NIS2, DORA y otros marcos europeos.
- Informar estrategias de inversión pública y privada en ciberseguridad.
- Facilitar un diálogo más adulto entre CISOs y consejos de administración.

La guía puede evolucionar con nuevas versiones de marcos normativos y con las lecciones extraídas de las primeras oleadas de la encuesta. A fin de cuentas, la madurez también se mide por la capacidad de cambiar de opinión con datos en la mano.